INFORME TÉCNICO DE AUDITORÍA DE SEGURIDAD

VEROTINOW

Análisis estático de APK padre, APK hijo e infraestructura asociada

Veredicto: CRÍTICO — dropper Android y troyano de acceso remoto (RAT), con módulos compatibles con captura de credenciales y fraude financiero.

Campo	Detalle
Fecha del análisis	1 de noviembre de 2026
Analista	Auditoría estática asistida por IA
Clasificación	Confidencial / uso defensivo
Alcance	APK padre, APK hijo, payload embebido, sitio señuelo e infraestructura identificada
Ejecución del malware	No ejecutado; análisis estático y revisión pasiva

Documento elaborado con fines educativos y defensivos. Los indicadores se presentan para detección, respuesta y bloqueo; no se incluyen instrucciones para conectarse al servidor de mando y control.

Contenido

- 1. Resumen ejecutivo
- 2. Alcance, metodología y limitaciones
- 3. Arquitectura de la campaña
- 4. APK padre: dropper
- 5. APK hijo: RAT y permisos
- 6. Infraestructura C2 y sitio señuelo
- 7. Capacidades observadas e impacto
- 8. Mapeo MITRE ATT&CK;
- 9. Evaluación de riesgo
- 10. Indicadores de compromiso (IOC)
- 11. Detección y respuesta
- 12. Maqueta web segura
- 13. Conclusiones y anexos

Nota sobre las imágenes: la infografía incluida es una pieza explicativa generada para difusión. No constituye una captura forense del APK ni una captura verificada del sitio. No se proporcionaron capturas originales de pantalla del instalador o del dispositivo; por ello no se presentan recreaciones como evidencia real.

1. Resumen ejecutivo

VerotiNow se promociona como una aplicación Android para ver películas y series en HD mediante el dominio mediaverotinow.com. La auditoría reportada identifica que el APK inicial no es un reproductor: actúa como dropper y contiene un segundo APK cifrado. El payload extraído corresponde a com.peakrelay.app, identificado como un RAT con capacidades de control remoto, persistencia, captura de pantalla, captura de entradas y superposiciones de phishing.

La cadena técnica observada conecta la landing, el instalador y el RAT mediante el identificador 832336. El sitio utiliza el parámetro `aid=832336`; el APK hijo registra el mismo valor como `accountBindId` y `apkAccountBindId` al preparar su registro con la infraestructura C2.

El análisis no encontró una API key estática convencional. La clave Base64 localizada corresponde al descifrado local del payload SVLT-XOR v2. Los tokens Bearer de transferencia se describen como dinámicos y no fueron obtenidos, ya que no se interactuó con el servidor.

Conclusión ejecutiva: la combinación de control remoto, persistencia y formularios superpuestos que solicitan PIN de desbloqueo o PIN de pago justifica clasificar el caso como crítico. Cualquier dispositivo donde se haya instalado el APK debe tratarse como potencialmente comprometido.

2. Alcance, metodología y limitaciones

2.1 Elementos examinados

Elemento	Identificación
APK padre	com.system.loader.va363d031 — v5.35.9; versionCode 1711774
APK hijo	com.peakrelay.app — v1.0.1748; versionCode 1749
Payload cifrado	assets/1lez0j83xpsa5vj0 — contenedor SVLT v2
Sitio señuelo	https://mediaverotinow.com/
Infraestructura C2	ktxapp.com y ktx123.net

2.2 Metodología

• Extracción y desempaquetado estático del APK padre; revisión de manifiesto, recursos, cadenas y clases mediante JADX.

• Identificación del contenedor SVLT v2 y descifrado offline del payload para extraer el APK hijo.

• Revisión estática independiente del manifiesto y código del APK hijo.

• Análisis pasivo de DNS/WHOIS y descarga únicamente del HTML público de la landing.

• Documentación de hashes, certificados, dominios, rutas y cadenas relevantes para detección.

2.3 Limitaciones

• No se ejecutó ningún APK en un dispositivo real ni en un entorno dinámico.

• No se contactó con el C2, no se enviaron identificadores ni tokens y no se solicitaron rutas de descarga del APK.

• No se dispone del panel del operador ni de respuestas de servidor; el comportamiento dinámico no está confirmado.

• La atribución a un actor concreto no está establecida. Los datos de infraestructura no bastan por sí solos para atribuir nacionalidad o identidad.

3. Arquitectura de la campaña

La campaña se compone de una web señuelo, un instalador de primera etapa y una carga útil Android de segunda etapa. El diseño desacopla la apariencia visible del código de control remoto.

Etapa	Componente	Función observada
1	mediaverotinow.com	Catálogo ficticio y botón de descarga; parámetro aid=832336.
2	com.system.loader.va363d031	Instalador AppHub; descifra el payload y solicita instalación.
3	com.peakrelay.app	RAT; solicita permisos sensibles y prepara registro remoto.
4	ktxapp.com / ktx123.net	Infraestructura identificada como C2 en el análisis estático.

Relación técnica clave

El valor 832336 aparece en la landing como `aid` y en el APK hijo como `accountBindId` y `apkAccountBindId`. Esta coincidencia es el pivote de correlación más sólido descrito en el análisis.

El flujo anterior representa la arquitectura deducida del código y del HTML revisados; no representa una sesión observada en vivo contra el C2.

4. APK padre — dropper

Campo	Valor
Paquete	com.system.loader.va363d031
Versión	5.35.9 (versionCode 1711774)
SDK	minSdk 24 / targetSdk 36
SHA-256	bb800888897880a32c7bbdae353b4de9d7972b0cf4d89b4ccef4ef77a4c0abb5
Certificado	CN=Nova Build 20260703113341, O=Nova, C=SG
Actividad de entrada	com.system.loader.va363d031.bootstrap.LaunchRouterActivity
Payload	assets/1lez0j83xpsa5vj0

4.1 Apariencia e ingeniería social

El padre utiliza la marca interna AppHub Installer y textos que describen un servicio de instalación seguro. La actividad de entrada dirige a MainActivity y presenta una secuencia de progreso mientras materializa el APK hijo. La solicitud de `REQUEST_INSTALL_PACKAGES` es el permiso esencial para completar la instalación de la segunda etapa.

4.2 Permisos del padre

`REQUEST_INSTALL_PACKAGES`, `FOREGROUND_SERVICE`, `FOREGROUND_SERVICE_DATA_SYNC`, `POST_NOTIFICATIONS`, `WAKE_LOCK` y un permiso interno de receiver. El manifiesto minimalista reduce las señales visibles antes de instalar el hijo.

4.3 Payload SVLT v2

El asset comienza con la firma `SVLT`, versión 2 y un IV de 16 bytes. El código descrito aplica XOR repetido entre el byte cifrado, la clave y el IV. El resultado es un ZIP que contiene `payload/child.apk`.

Clave de descifrado local (no es una API key):

```
1N2D8iXa2V5XMOLfUBbUtmtPYkx7XaHzuKnAXCzTGUc=
```

El hash esperado del APK hijo indicado en la configuración es e3c694302f289a4d29cef62a5113bbbb04d9179cda642474a84ceebbdfa12470. Aunque la configuración declara `verify_signature: true`, la revisión reportada no encontró una verificación criptográfica efectiva previa a la instalación. La declaración del JSON no debe tomarse como garantía.

5. APK hijo — RAT y permisos

Campo	Valor
Paquete	com.peakrelay.app
Versión	1.0.1748 (versionCode 1749)
SDK	minSdk 24 / targetSdk 34
SHA-256	e3c694302f289a4d29cef62a5113bbbb04d9179cda642474a84ceebbdfa12470
Certificado	CN=Remote Control, O=YuanKong, C=CN
Clase Application	com.remote.control.RemoteControlApp
Preferencias	remote_control_prefs

5.1 Permisos y capacidades sensibles

Área	Permisos / componentes	Riesgo asociado
Accesibilidad	BIND_ACCESSIBILITY_SERVICE; captura de pantalla, eventos y gestos	Lectura e interacción con la interfaz.
Entrada	canRequestFilterKeyEvents; servicio de método de entrada	Captura de entradas; potencial keylogging.
Superposición	SYSTEM_ALERT_WINDOW	Ventanas falsas sobre aplicaciones legítimas.
Archivos	MANAGE_EXTERNAL_STORAGE; READ/WRITE y READ_MEDIA_*	Acceso amplio a archivos y medios.
Dispositivo	Administrador de dispositivo; force-lock y disable-keyguard-features	Bloqueo y fricción para retirar la app.
Aplicaciones	QUERY_ALL_PACKAGES; REQUEST_DELETE_PACKAGES	Inventario y gestión de apps.
Ubicación y conectividad	ACCESS_FINE_LOCATION, ACCESS_COARSE_LOCATION, Wi-Fi y Bluetooth	Obtención de contexto del dispositivo.
Persistencia	RECEIVE_BOOT_COMPLETED, WAKE_LOCK, alarmas y exclusión de batería	Reinicio y continuidad en segundo plano.

Importante: el manifiesto revisado no declara CAMERA ni RECORD_AUDIO. Aunque el enum de mensajes incluye nombres relacionados con cámara y audio, no debe afirmarse que el malware pueda capturar cámara o micrófono reales con la evidencia disponible. La captura de pantalla sí aparece respaldada por la configuración del servicio de accesibilidad.

5.2 Componentes relevantes

Componente	Función identificada
ConnectionService	Conexión C2, heartbeat y despacho de comandos.
RemoteAccessibilityService	Captura de pantalla, gestos, teclas, árbol UI y overlays.
RemoteInputMethodService	Servicio de teclado propio.
WatchdogService / GuardianService	Vigilancia y recuperación de servicios.
KeepAliveAssistService / KeepAliveJobService	Reintentos y supervivencia en segundo plano.
BootReceiver / ConnectionRecoveryReceiver	Reacción al reinicio y recuperación de conexión.
RemoteDeviceAdminReceiver / AntiUninstallGuard	Privilegios de administración y resistencia a desinstalación.
SelfUninstallActivity / AppUninstallActivity	Flujos de eliminación controlados.

6. Infraestructura C2 y sitio señuelo

Indicador	Valor
Servidor principal	https://ktxapp.com
Socket.IO	wss://ktxapp.com/socket.io/
Stream binario	wss://ktxapp.com/ws/binary-device
Reporte	https://ktxapp.com/api/strategies/report y /report
Fallback	https://ktx123.net
IP observada en el análisis	206.82.1.14 (1-nov-2026; dato reportado)
Landing	https://mediaverotinow.com/

El cliente Android contiene lógica de registro mediante un evento `register` y parámetros que incluyen identificadores de dispositivo, fingerprint y datos de campaña. La conexión descrita utiliza WSS y un canal binario con keepalive. Estos detalles se consignan para detección; no se realizó conexión ni reproducción del protocolo.

6.1 Landing de distribución

El HTML público revisado contiene una variable de runtime con descarga habilitada y rutas para descarga, vinculación de sesión y manifiesto público. El parámetro Base64 `YWlkPTgzMjMzNg==` decodifica a `aid=832336`. El botón y los elementos promocionales dirigen al usuario hacia la ruta de descarga. También se identificó lógica para navegadores integrados de Meta que intenta abrir Chrome mediante un intent.

El uso de Cloudflare como registrador, DNS, CDN o proxy no demuestra participación de Cloudflare en la campaña. La IP de origen real puede estar oculta por el proxy.

7. Capacidades observadas e impacto

Categoría	Ejemplos de comandos/cadenas	Impacto potencial
Control remoto	CLICK, SWIPE, GESTURE, BACK, HOME, KEY_INPUT	Interacción remota con el dispositivo.
Pantalla e interfaz	SCREEN_FRAME, REQUEST_SCREEN, CAPTURE_UI_TREE	Observación de información visible.
Captura de datos	KEY_INPUT, CLIPBOARD_SYNC, DEVICE_INFO, GET_LOCATION	Exposición de entradas, portapapeles y contexto.
Archivos y apps	FILE_LIST, FILE_UPLOAD, FILE_DOWNLOAD, LAUNCH_APP, UNINSTALL_APP	Acceso y manipulación de datos y aplicaciones.
Persistencia	ANTI_UNINSTALL_ENABLE, HIDE_APP_ICON, BootReceiver	Dificultad para detectar y retirar el malware.
Phishing financiero	ARM_PIN_CAPTURE, ARM_PAYMENT_CAPTURE, PAYMENT_PIN_REPORT	Robo potencial de PIN de desbloqueo y pago.

Las cadenas reportadas incluyen solicitudes como “Please enter your payment PIN to verify” y “Enter lock screen password to unlock”. Junto con los comandos de captura y reporte, estas cadenas son consistentes con overlays destinados a obtener credenciales. El código estático demuestra la presencia de módulos y flujos; el éxito de un fraude concreto no fue observado dinámicamente.

8. Mapeo MITRE ATT&CK; (orientativo)

Táctica	Técnica	Evidencia resumida
Initial Access	T1204.002 — User Execution: Malicious File	Instalación manual del APK.
Initial Access	T1660 — Phishing	Landing que induce a descargar la app.
Execution	T1407 — Download New Code at Runtime (Mobile)	Payload secundario materializado.
Execution	T1546 — Event Triggered Execution	BootReceiver, alarmas y servicios persistentes.
Defense Evasion	T1036 — Masquerading	Marcas AppHub Installer y VerotiNow Core.
Defense Evasion	T1406 — Obfuscated Files or Information	Payload cifrado SVLT-XOR.
Defense Evasion	T1564.008 — Hide Artifacts: Hide in Launcher	Alias e instrucción para ocultar icono.
Discovery	T1426 — System Information Discovery	DEVICE_INFO y fingerprint.
Discovery	T1418 — Software Discovery	Inventario de aplicaciones.
Collection	T1113 — Screen Capture	takeScreenshot y SCREEN_FRAME.
Collection	T1056.001 — Input Capture: Keylogging	Filtro de eventos de teclado y KEY_INPUT.
Collection	T1414 — Clipboard Data	CLIPBOARD_SYNC.
Collection	T1430 — Location Tracking	GET_LOCATION.
Command and Control	T1437 — Application Layer Protocol	Socket.IO sobre WebSocket.
Command and Control	T1573 — Encrypted Channel	TLS/WSS.
Exfiltration	T1041 — Exfiltration Over C2 Channel	Reportes de datos a través del C2.
Impact	T1657 — Financial Theft	Módulos de captura de PIN y pago.

El mapeo es orientativo. Antes de utilizarlo en un reporte formal de inteligencia de amenazas, conviene validar cada técnica contra la versión vigente de MITRE ATT&CK; for Mobile y distinguir técnicas confirmadas por código de técnicas solo sugeridas por nombres de comandos.

9. Evaluación de riesgo

Dimensión	Evaluación
Confidencialidad	Crítica: pantalla, entradas, portapapeles, archivos, ubicación y notificaciones.
Integridad	Alta: gestos, instalación/desinstalación y cambios de configuración.
Disponibilidad	Alta: bloqueo, pantalla negra y persistencia.
Impacto financiero	Crítico: overlays de pago y captura de PIN.
Facilidad de infección	Media: requiere instalación manual y concesión de permisos; el señuelo facilita la ingeniería social.
Detección	Media-baja: ofuscación, ocultación del icono y comunicación cifrada.
Riesgo global	CRÍTICO — 9,0 a 10,0 (estimación cualitativa del informe).

10. Indicadores de compromiso (IOC)

10.1 Dominios y rutas

```
ktxapp.com · www.ktxapp.com · ktx123.net · www.ktx123.net · mediaverotinow.com · www.mediaverotinow.com
```

Rutas observadas en el análisis: /socket.io/ · /ws/binary-device · /api/strategies/report · /report · /go?aid=832336 · /api/landing-bind-session?aid=832336 · /api/apks/public-manifest?aid=832336

10.2 Paquetes Android

```
com.system.loader.va363d031 (dropper)
com.peakrelay.app (RAT)
```

10.3 Hashes SHA-256

```
APK padre: bb800888897880a32c7bbdae353b4de9d7972b0cf4d89b4ccef4ef77a4c0abb5
APK hijo: e3c694302f289a4d29cef62a5113bbbb04d9179cda642474a84ceebbdfa12470
Asset cifrado: 03e41c3cdff5f0bcad3512a93b56f517b585e8017c3ec6fab7a97df989a2afb1
```

10.4 Identificadores de campaña

```
accountBindId / apkAccountBindId: 832336
apkAccountId: account_mucgaqvz_b71f5673a748
apkAccountName: lx5-001
downloadSiteId: landing
Fingerprint: peakrelay-device-v2 / protube-device-v2
```

11. Detección y respuesta

11.1 Comprobaciones defensivas en Android

Los siguientes comandos son consultas de inventario y diagnóstico mediante ADB; no instalan ni ejecutan el APK:

```
adb shell pm list packages | grep -E 'com\\.system\\.loader\\.|com\\.peakrelay\\.app'
adb shell settings get secure enabled_accessibility_services
adb shell dumpsys accessibility | grep -i -E 'veroti|peakrelay|remote'
adb shell dumpsys device_policy | grep -i -E 'peakrelay|veroti|remote'
adb shell dumpsys package com.peakrelay.app | grep -E
'granted=true|ACCESSIBILITY|SYSTEM_ALERT|MANAGE_EXTERNAL'
```

Señales de alerta: aplicación instalada fuera de Google Play, servicio de accesibilidad desconocido, administrador de dispositivo no reconocido, icono ausente mientras el paquete sigue instalado, overlays que solicitan PIN o tráfico hacia los dominios identificados.

11.2 Contención de red

• Bloquear los dominios ktxapp.com y ktx123.net en DNS, proxy y controles de navegación, considerando sus subdominios.

• Crear alertas para conexiones TLS hacia la IP reportada y para SNI ktxapp.com, verificando primero que la inteligencia siga vigente.

• Buscar en registros históricos las rutas y el identificador 832336.

• Preservar logs, fechas, hashes y muestras originales; documentar zona horaria y cadena de custodia.

11.3 Recomendaciones para usuarios afectados

• Suspender el uso del dispositivo para banca y pagos. No introducir PIN ni contraseñas en él.

• Desde otro dispositivo confiable, contactar al banco, revisar movimientos y bloquear temporalmente medios de pago si existe sospecha de exposición.

• Si el malware está instalado, tratar el dispositivo como comprometido. La medida más fiable es restablecerlo de fábrica después de preservar la evidencia necesaria.

• Cambiar contraseñas principales desde un dispositivo limpio, cerrar sesiones activas y activar autenticación multifactor.

• Reinstalar únicamente aplicaciones desde tiendas oficiales y aplicar las actualizaciones del sistema.

11.4 Recomendaciones para organizaciones

• Restringir la instalación de APK fuera de fuentes gestionadas mediante MDM.

• Auditar permisos de Accesibilidad, administrador de dispositivo y superposición.

• Buscar los hashes, paquetes, dominios y cadenas de detección en los controles disponibles.

• Incluir campañas de concienciación que contemplen falsas plataformas de streaming, no solo phishing por correo.

12. Maqueta web segura

La maqueta `verotinow-movies/` se mantuvo separada de la infraestructura maliciosa. Su backend local sirve un catálogo ficticio en modo de solo lectura; no actúa como cliente del C2.

Archivo	Responsabilidad
server.py	Servidor HTTP local y endpoints /api/*.
catalog.json	Catálogo de 18 títulos ficticios.
config.js	Configuración de API same-origin y timeout.
app.js	fetch, validación de datos, renderizado y fallback.
index.html	Interfaz y aviso de demostración.
README.md	Instrucciones de ejecución.

Endpoints locales documentados: GET /api/health, GET /api/catalog, GET /api/featured, GET /api/catalog/ y OPTIONS /api/*. El servidor se ejecuta en 127.0.0.1:8787. El cliente valida el esquema recibido, limita longitudes, comprueba colores con una expresión regular e inserta texto con textContent para reducir el riesgo de inyección.

Decisión de seguridad: no se conectó la web a ktxapp.com ni a ktx123.net; tampoco se reprodujo el registro del APK, se enviaron identificadores, se descargaron binarios ni se implementó WebSocket/Socket.IO. Una integración futura de metadatos legítimos debe realizarse a través de un backend propio y mantener las claves fuera del navegador.

13. Conclusiones

La evidencia estática descrita identifica una cadena de dos etapas: un instalador de apariencia legítima que descifra un payload secundario y un APK hijo con capacidades de control remoto. Los permisos de accesibilidad, captura de pantalla, filtrado de entradas, superposición, acceso amplio a archivos, administración del dispositivo y persistencia representan un riesgo elevado.

Los módulos y cadenas vinculados a captura de PIN de bloqueo y PIN de pago elevan el impacto potencial a fraude financiero. El identificador 832336, los dominios, los paquetes y los hashes constituyen los principales pivotes de correlación y detección.

Recomendación final: cualquier dispositivo en el que se haya instalado VerotiNow debe tratarse como potencialmente comprometido. Para una recuperación de alta confianza, se recomienda restablecimiento de fábrica y cambio de credenciales desde otro dispositivo limpio, además de revisión bancaria.

Anexo A. Evidencia y trazabilidad

Evidencia	Ubicación reportada durante el análisis
APK padre extraído	/tmp/opencode/apk/extracted/
Código padre	/tmp/opencode/apk/jadx_full/sources/
Configuración vault	/tmp/opencode/apk/extracted/assets/vault-config.json
Asset cifrado	/tmp/opencode/apk/extracted/assets/1lez0j83xpsa5vj0
APK hijo descifrado	/tmp/opencode/apk/child.apk
Código hijo	/tmp/opencode/apk/jadx_child/sources/
Manifiesto hijo	/tmp/opencode/apk/jadx_child/resources/AndroidManifest.xml
HTML landing	/tmp/opencode/mediaverotinow.html
Maqueta web	/home/mvlwvr3/verotinow-movies/

Anexo B. Cronología reportada

Fecha	Evento
2026-09-03	Registro de ktxapp.com (dato WHOIS reportado).
2026-09-04	Registro de ktx123.net (dato WHOIS reportado).
2026-10-11	Registro de mediaverotinow.com (dato WHOIS reportado).
2026-11-01	Análisis estático y documentación.

Anexo C. Nota de evidencia visual

La infografía de la página siguiente es material de concienciación generado a partir de los hallazgos proporcionados. Los teléfonos y pantallas representados son ilustraciones conceptuales; no deben citarse como capturas originales ni como prueba de que una interfaz concreta apareció en un dispositivo. Para una versión probatoria del informe, incorporar capturas originales obtenidas durante el análisis, con fecha, fuente y hash del archivo.

Anexo D. Infografía de concienciación

Pieza visual para difusión pública. Antes de publicarla, evita exponer datos personales o información que pueda identificar a víctimas.

